以攻防为刃，守护数字边界；
以技术为基，探索安全世界。

---

# 网络安全攻防竞赛实践
# 课程笔记

---

**内容概要：** Web 安全 | 二进制 Pwn | 密码学 | MISC | 渗透测试

**适用场景：** 课程学习 • 竞赛备赛 • 知识点速查

**整理者：** duckweed

整理日期：2026 年 11 月 6 日

---

**版本：** v1.0 完整版

原创笔记 • 禁止商用 • 欢迎交流学习

---

# 目录

**1 绪论** **1**
1.1 网络安全攻防竞赛（CTF）概述 . . . 1
1.2 CTF 竞赛模式 . . . 1
1.3 CTF 竞赛主要题型 . . . 1
1.4 CTF 主流赛事 . . . 2
1.5 Write-Up（WP）书写规范 . . . 2
1.5.1 WP 基本要求 . . . 2
1.6 CTF 备赛方法 . . . 2
1.7 课程学习与实践路径 . . . 3
1.8 法律与合规要求 . . . 3
1.9 本笔记编写目的 . . . 3

**2 杂项（Misc）安全** **4**
2.1 Misc 概述 . . . 4
2.1.1 Misc 核心学习参考 . . . 4
2.1.2 Misc 核心考察方向 . . . 4
2.2 Misc 常用工具介绍 . . . 4
2.2.1 CyberChef 工具详解 . . . 4
2.3 编码分析 . . . 6
2.3.1 常见编码方式 . . . 6
2.3.2 编码载体与常见场景 . . . 6
2.3.3 Base 系列编码特征 . . . 6
2.4 PyJail 沙箱逃逸例题：Truncate . . . 7
2.4.1 题目源码与分析 . . . 7
2.4.2 解题核心：Unicode 连字与 NFKC 标准化 . . . 7
2.4.3 Payload 构造 . . . 8
2.4.4 环境连接与执行 . . . 8
2.5 隐写术（Steganography） . . . 8
2.5.1 隐写术概述 . . . 8
2.5.2 文件识别基础 . . . 9
2.5.3 图像隐写（LSB 隐写详解） . . . 10
2.5.4 音频隐写（摩斯码隐写详解） . . . 10
2.5.5 文本隐写 . . . 11
2.5.6 隐写术通用解题思路 . . . 11
2.6 隐写术常用工具汇总 . . . 12
2.7 网络安全竞赛通用工具清单 . . . 12
2.8 参考文献 . . . 12

**3 Web 安全 13**
3.1 Web 安全概述 . . . 13
3.1.1 Web 核心学习参考 . . . 13
3.1.2 Web 核心考察方向 . . . 13
3.2 Web 常用工具介绍 . . . 15
3.2.1 Kali Linux 渗透测试系统 . . . 15
3.3 核心工具详解 . . . 16
3.3.1 Hackbar 工具 . . . 16
3.3.2 Burp Suite 工具 . . . 16
3.3.3 SQLmap 工具 . . . 16
3.4 HTTP 请求协议基础 . . . 17
3.4.1 GET 请求 . . . 17
3.4.2 POST 请求 . . . 17
3.4.3 HTTP 常见请求头 . . . 17
3.5 HTTP 请求示例 . . . 18
3.5.1 GET 请求示例 . . . 18
3.5.2 POST 请求示例 . . . 18
3.6 Hackbar 使用实验 . . . 19
3.6.1 实验目的 . . . 19
3.6.2 实验步骤 . . . 19
3.6.3 实验要求 . . . 19
3.7 Web 安全通用解题思路 . . . 20
3.8 参考文献 . . . 21

# 1 绪论

## 1.1 网络安全攻防竞赛（CTF）概述

网络安全攻防竞赛（CTF，Capture The Flag，夺旗赛）起源于 1996 年 DEF CON 全球黑客大会，是网络安全领域的核心竞技形式。

参赛团队通过攻防对抗、程序分析等方式，从比赛环境中获取特定格式的字符串（即 Flag，格式一般为 `flag{xxx}`），提交后获得分数，并最终提交 Write-Up（解题报告，简称 WP）。

CTF 竞赛以实战化场景检验参赛人员的漏洞挖掘、渗透测试、逆向分析、密码学破解、应急响应等综合能力，是网络安全人才培养、技术交流与选拔的重要平台。

## 1.2 CTF 竞赛模式

CTF 主要分为两种竞赛模式：

- **解题模式（Jeopardy）**
  多用于线上初赛，依托互联网进行。主办方将题目部署在竞赛平台，选手登录后解题，提交 Flag 得分，按总分排名。

- **攻防模式（Attack-Defense，AWD）**
  多用于线下决赛，依托局域网进行。各队伍拥有相同的靶机环境，需要同时进行漏洞利用（攻击）与安全加固（防御）。

## 1.3 CTF 竞赛主要题型

CTF 竞赛题目覆盖网络安全全领域，主要包括以下六大类：

- **Web**：Web 应用漏洞挖掘、SQL 注入、XSS、文件上传、命令执行等
- **Pwn**：二进制漏洞利用、堆栈溢出、格式化字符串、ROP、沙箱绕过等
- **Crypto**：古典密码、对称/非对称加密、哈希算法、密码分析等
- **Reverse**：程序逆向、静态分析、动态调试、加壳脱壳等
- **Misc**：隐写术、流量分析、电子取证、硬件安全等
- **其他**：移动安全、工控安全、区块链安全、AI 安全等

## 1.4 CTF 主流赛事

国内具有广泛影响力的 CTF 赛事包括：

- 全国大学生信息安全竞赛（CISCCTF）
- “强网杯”全国网络安全挑战赛
- 国际网络安全技术对抗联赛（XCTF）
- 腾讯信息安全争霸赛（TCTF）
- DEF CON CHINA CTF
- 网鼎杯、蓝帽杯、鹏城杯、羊城杯、湖湘杯等

## 1.5 Write-Up（WP）书写规范

Write-Up 是 CTF 竞赛中必须提交的解题报告，用于记录解题思路、方法、工具与过程，是比赛评分与技术交流的重要依据。

### 1.5.1 WP 基本要求

1. **书面性**：以 PDF、Markdown、Word 等可读格式呈现，可包含截图、代码。
2. **完整性**：包含解题全过程，关键步骤不可缺失。
3. **原创性**：必须为独立完成，引用工具需注明来源。
4. **可读性**：逻辑清晰、排版规范，可复现解题过程。

## 1.6 CTF 备赛方法

- 夯实计算机基础：计算机网络、操作系统、编程语言
- 熟练掌握至少一门编程语言（推荐 Python）
- 搭建实验环境，练习漏洞复现
- 掌握常用安全工具：Burp Suite、IDA、GDB、Wireshark 等
- 大量刷题并独立书写 WP
- 学习优秀 Write-Up，拓展解题思路
- 积极参加线上线下比赛，以赛促学
- 赛后及时复盘，总结经验与不足

## 1.7 课程学习与实践路径

- **讲解**：知识点梳理、工具介绍、基础操作
- **演示**：典型题目完整解题过程示范
- **复现**：学生独立复现演示题目
- **实践**：完成竞赛题目并提交 WP

## 1.8 法律与合规要求

网络安全技术具有高风险性，所有学习与竞赛活动必须严格遵守法律法规。《中华人民共和国网络安全法》明确规定：

> 国家采取措施，监测、防御、处置来源于境内外的网络安全风险和威胁，保护关键信息基础设施免受攻击、侵入、干扰和破坏，依法惩治网络违法犯罪活动，维护网络空间安全和秩序。

- 严禁未经授权对任何系统进行攻击、入侵
- 仅在授权环境下开展技术研究与竞赛
- 遵守竞赛规则与法律底线，合法合规学习

## 1.9 本笔记编写目的

本笔记系统梳理网络安全攻防竞赛的基础知识、题型分类、解题方法、备赛路径与规范要求，为课程学习、竞赛备赛、技术速查提供完整、实用的参考资料。

# 2 杂项（Misc）安全

## 2.1 Misc 概述

Misc（杂项）是 CTF 竞赛中覆盖范围最广、形式最灵活的题型，主要考察参赛人员的综合分析能力、编码解码能力、隐写分析能力、网络流量分析能力等。

### 2.1.1 Misc 核心学习参考

- CTF Wiki 杂项简介：https://ctf-wiki.org/misc/introduction/
- CTF 之 misc 杂项解题技巧总结（一）——编码与加密：https://blog.csdn.net/zjzqxzhj/article/details/128030485
- CTF 学习-MISC 杂项解题思路：https://blog.csdn.net/qq_44204058/article/details/119963204
- Misc 详细参考：https://www.cnblogs.com/limestone/p/16869417.html

### 2.1.2 Misc 核心考察方向

Misc 题目涉及知识面广泛，核心考点主要包括：

- 各类编码解码
- 隐写术分析
- 网络流量分析
- 压缩包分析与破解
- 系统日志分析
- 电子取证
- 信息收集与整理
- **PyJail 沙箱逃逸**（Python 代码执行限制绕过）

## 2.2 Misc 常用工具介绍

### 2.2.1 CyberChef 工具详解

CyberChef 是一款开源、跨平台、功能强大的在线数据处理工具，被称为“网络安全瑞士军刀”，支持各类编码、加密、哈希、格式转换等操作，是 CTF Misc 题型的高频使用工具。

表 1: Misc 题型常用工具清单

| 工具名称 | 工具用途 |
| --- | --- |
| WinHex / HxD / 010 Editor | 十六进制编辑器，用于文件底层结构分析 |
| strings | Linux 命令，提取文件中的可打印字符串 |
| binwalk | 检测并提取文件中隐藏的资源 |
| foremost | 文件恢复与隐藏文件提取 |
| file | Linux 命令，识别文件类型 |
| StegSolve | 图片隐写分析工具，支持位平面与 LSB 分析 |
| Photoshop | 图像编辑与隐写分析 |
| Pillow | Python 图像处理库 |
| PNGcheck | PNG 文件结构检测工具 |
| Audacity | 音频处理与音频隐写分析 |
| Wireshark | 网络流量数据包分析 |
| ARCHPR | RAR/ZIP 压缩包密码破解 |
| CyberChef | 在线编码解码与数据处理工具 |
| 330k Unicode Steganography | 零宽字符文本隐写解密 |

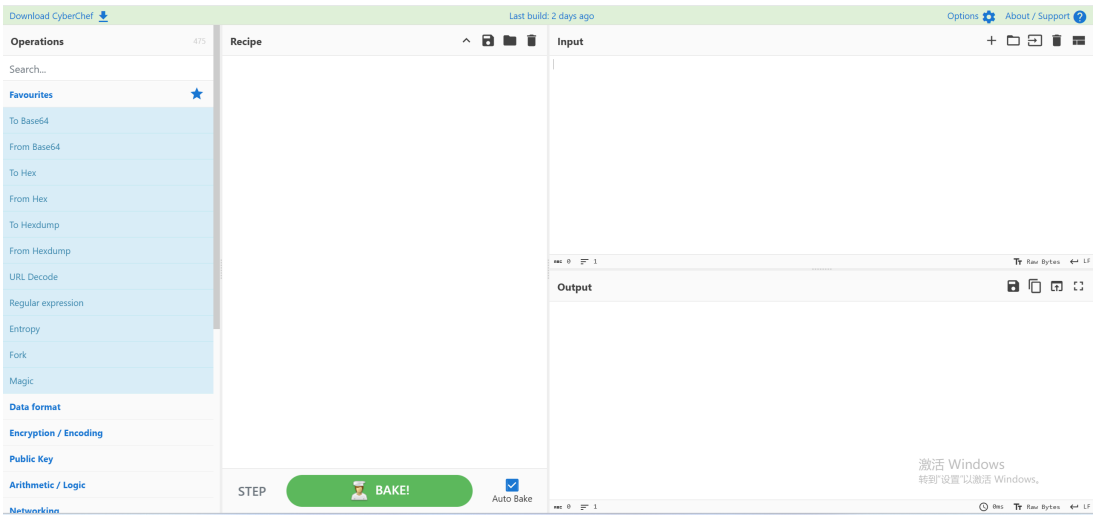



图 1: CyberChef 工具界面与工作流程

在线地址：https://gchq.github.io/CyberChef
工具使用流程：

1. **Input**：输入待处理数据
2. **Operations**：选择需要的操作
3. **Recipe**：组合多步处理操作
4. **Output**：点击 BAKE! 获得结果

## 2.3 编码分析

### 2.3.1 常见编码方式

CTF 中高频出现的编码类型：

- ASCII 编码
- Base64 / Base32 等 Base 系列编码
- 摩尔斯电码
- ROT 系列编码
- Unicode 编码（含连字、NFKC 标准化）
- URL 编码

参考资料：https://ctf-wiki.org/misc/encode/computer/#base

### 2.3.2 编码载体与常见场景

- **载体形式**：flag 通常以编码字符串形式隐藏
- **签到题**：直接给出多层嵌套编码
- **隐藏题**：编码内容藏于流量、图片等文件中，需先提取再解码

### 2.3.3 Base 系列编码特征

**Base64 编码特征：**

- 字符集：A-Z、a-z、0-9、+、/
- 结尾可能有填充符 =

**Base32 编码特征：**

- 字符集：A-Z、2-7
- 仅大写字母与数字，无 +/
- 结尾可能有填充符 =

## 2.4 PyJail 沙箱逃逸例题：Truncate

### 2.4.1 题目源码与分析

```
#!/usr/bin/python3 -S
flag = open("flag.txt", "r").read().strip()
eval(input("")[:8])
```

#### 代码解析

- `-S`：禁用 site 模块，不影响本题核心逻辑
- 读取 flag.txt 内容存入变量 `flag`
- 获取用户输入，仅保留前 8 个字符，使用 `eval()` 执行

#### 限制与目标

- **限制**：输入长度最多 8 个字符
- **目标**：执行代码并泄露 `flag`
- **难点**：`print(flag)` 长度为 9，超出限制

### 2.4.2 解题核心：Unicode 连字与 NFKC 标准化

Python 在执行 `eval()` 前，会自动对字符串进行 NFKC 标准化。部分 Unicode 连字字符会被展开为多个普通字符：

- `U+FB01` → `fi`
- `U+FB03` → `ffi`
- `U+FB00` → `ff`

利用该特性，可以实现 **1 个字符输入 → 展开为多个字符 **，从而突破长度限制。

#### 2.4.3 Payload 构造

构造 Payload：

```
U+FB01 (flag)
```

经过 NFKC 标准化后变为：

```
int(flag)
```

长度仅 6 个字符，符合 8 字符限制，可成功执行并输出 flag。

#### 2.4.4 环境连接与执行

- 环境：SEEDUbuntu 虚拟机
- 连接命令：`nc <IP> <Port>`
- 输入 Payload：`int(flag)` 获取 flag

### 2.5 隐写术（Steganography）

#### 2.5.1 隐写术概述

隐写术是将秘密信息隐藏在图片、音频、视频、文本、压缩包等载体中，实现隐蔽传输的技术，是 CTF Misc 中的核心考点。

**CTF 中隐写术的常见特点**

- 题目多以文件附件形式给出，文件可能无后缀，需先识别文件类型
- 隐写术常与混淆、编码、密码学相结合，需多层分析才能提取 flag

**常见载体**

- 图片（PNG、BMP）
- 音频（WAV、MP3）
- 文本（零宽字符隐写）
- 压缩包（伪加密、文件合并）

### 2.5.2 文件识别基础

#### 文件识别方法

- **后缀名识别**：通过文件后缀初步判断类型（不可靠，可伪造）
- **工具识别**：使用 `file` 命令（Linux）、`010 Editor` 等工具分析
- **文件头识别**：通过文件开头的魔数（Magic Number）精准识别文件类型（最可靠）

表 2: CTF 常见文件类型与对应文件头

| 文件类型 | 文件头（十六进制） |
|---|---|
| JPEG (jpg) | FFD8FFE1 |
| PNG (png) | 89504E47 |
| GIF (gif) | 47494638 |
| TIFF (tif) | 49492A00 |
| Windows Bitmap (bmp) | 424DC001 |
| ZIP Archive (zip) | 504B0304 |
| RAR Archive (rar) | 52617221 |
| Adobe Photoshop (psd) | 38425053 |
| Rich Text Format (rtf) | 7B5C727466 |
| XML (xml) | 3C3F786D6C |
| HTML (html) | 68746D6C3E |
| Adobe Acrobat (pdf) | 255044462D312E |
| Wave (wav) | 57415645 |
| pcap (pcap) | 4D3C2B1A |

#### 常见文件头对照表

#### 文件操作常用工具

- **判断文件类型**：`file`（Linux 命令）
- **查看/修改文件**：`WinHex`、`010 Editor`、`notepad++`、`Hex Editor`
- **分离文件**：`binwalk`、`foremost`、`dd`
- **文件检测/处理**：`Stegsolve`、`Pillow`
- **文件合并**：`cat`（Linux）、`copy`（Windows）

### 2.5.3 图像隐写（LSB 隐写详解）

**LSB 隐写核心原理** LSB（Least Significant Bit，最低有效位）是一种常见的信息隐藏方法。图像像素一般由 RGB 三原色组成，每一种颜色占 8 位（`0x00 0xFF`，即 256 种颜色），而人的肉眼能区分的只有其中一小部分。

LSB 隐写就是修改 RGB 颜色分量中最低的二进制位：

- 仅修改像素中最低的 1 bit，肉眼完全无法区分前后变化
- 每个像素可携带 3 bit 信息（RGB 三通道各 1 bit）
- 不影响图片正常显示，同时隐藏秘密信息（通常为 `flagxxx` 格式）

**StegSolve 实操步骤（图像隐写例题）**

1. 打开 StegSolve，加载目标图片
2. 点击 `Analyse` → `Data Extract`
3. 位平面设置：仅勾选 **Red 0、Green 0、Blue 0**（最低有效位）
4. 字节序设置：选择 `LSB First`，`Bit Order` 选择 `RGB`
5. 点击 `Preview` 查看隐藏数据，提取 flag 相关内容

### 2.5.4 音频隐写（摩斯码隐写详解）

**音频隐写核心原理** 音频隐写利用人耳对声音的不敏感特性，将秘密信息（如摩斯码）隐藏在音频文件中，通过分析音频波形提取信息。

**工具：Audacity 实操步骤**

1. 打开 Audacity，加载音频文件 `secret.wav`
2. 观察音频波形，识别有节奏的滴答声，对应摩斯码的点（•）和划（-）
3. 提取摩斯码序列
4. 使用在线摩斯码转换工具解码，得到 flag

**自动音频摩斯密码解码工具（无需看波形、无需听）**

- 在线音频摩斯自动解码:https://morsecode.world/international/decoder/audio-decoder-ada
  html
- 功能：直接上传音频文件，自动识别摩斯密码并输出明文
- 适用场景：CTF 音频隐写（滴答声类型摩斯密码）

**摩斯码隐写核心考点**

- 摩斯码基础：点（•）、划（-）、间隔（字符间隔/单词间隔）
- 音频波形分析：通过波形长短区分点和划
- 在线解码工具：快速将摩斯码转换为明文 flag

### 2.5.5 文本隐写

文本隐写利用不可见字符实现信息隐藏，典型为 ** 零宽字符隐写 **，将秘密信息编码进 Unicode 零宽字符中并嵌入普通文本，肉眼无法察觉。

**常见零宽字符**

- 零宽空格（U+200B）
- 零宽连接符（U+200D）
- 零宽非连接符（U+200C）

**分析工具与步骤**

- Sublime Text / VSCode：显示不可见字符，提取零宽字符序列
- 330k 官方零宽隐写工具:http://330k.github.io/misc_tools/unicode_steganography.html
- 备用在线工具：https://www.mzy0.com/ctftools/zerowidth1/

**标准解题流程**

1. 将含隐写的文本粘贴至 330k 零宽字符隐写工具
2. 点击 Decode 按钮直接提取隐藏信息
3. 对解码结果进行整理，得到最终 flag

### 2.5.6 隐写术通用解题思路

1. **文件类型识别**：用 `file/010 Editor` 识别载体，补全后缀
2. **载体针对性分析**：
   - 图片：StegSolve 位平面与 LSB 提取
   - 音频：Audacity 波形分析与摩斯码提取

- 文本：零宽字符提取与解码
- 压缩包：binwalk 提取并逐层解压

3. **编码/密码学处理：**对提取的信息进行解码、解密

4. **按正则构造 flag 并提交**

## 2.6 隐写术常用工具汇总

表 3: 隐写术全载体常用工具清单

| 工具名称 | 工具用途 |
|---|---|
| StegSolve / StegOnline | 图片位平面分析、LSB 提取、PNG 块分析 |
| Audacity | 音频处理、摩斯码提取与分析 |
| 010 Editor | 16 进制编辑、文件头识别 |
| Sublime Text | 零宽字符查看 |
| 330k Unicode Steganography | 零宽字符文本隐写解密 |
| CyberChef | 编码解码、LSB 提取 |
| binwalk | 隐藏文件提取 |
| 7-Zip / WinRAR | 压缩包解压 |

## 2.7 网络安全竞赛通用工具清单

表 4: 网络安全竞赛全题型常用工具

| 工具类别 | 代表工具 |
|---|---|
| 渗透测试 | Burp Suite、Nmap、Metasploit |
| 逆向分析 | IDA Pro、Ghidra、x64dbg |
| 密码学 | CyberChef、John the Ripper、Hashcat |
| 取证分析 | Wireshark、Volatility、Foremost |

## 2.8 参考文献

1.《CTF 那些事儿》，李舟军，机械工业出版社，2023

2.《CTF 特训营：技术详解、解题方法与竞赛技巧》，FlappPig 战队著，机械工业出版社，2022

3.《CTF 竞赛权威指南（Pwn 篇）》，杨超，电子工业出版社，2020

4.《白帽子 Web 安全》，吴翰清，电子工业出版社，2021

5.《CTF 安全竞赛入门》，张镇等，清华大学出版社，2020

6. Unicode 标准与规范化形式：https://unicode.org/reports/tr15/

7. Python eval 与 Unicode 标准化：https://docs.python.org/3/reference/lexical_analysis.html#unicode-normalization

8. 摩斯码在线转换工具：http://mosi.fjnews.com/

9. 音频摩斯密码自动解码工具：https://morsecode.world/international/decoder/audio-decoder-adaptive.html

10. 零宽字符隐写工具:http://330k.github.io/misc_tools/unicode_steganography.html

# 3 Web 安全

## 3.1 Web 安全概述

Web 安全是 CTF 竞赛中最核心、最常见的题型，主要考察参赛人员对 HTTP 协议、Web 应用漏洞原理、漏洞利用工具、代码审计及渗透测试思路的掌握程度，覆盖前后端全栈安全知识。

### 3.1.1 Web 核心学习参考

- CTF Wiki Web 安全：https://ctf-wiki.org/web/
- Burp Suite 实战指南:https://blog.csdn.net/qq_35544379/article/details/76696106
- SQL 注入从入门到精通：https://blog.csdn.net/phpppppppppp/article/details/124968358
- Hackbar 工具使用教程:https://blog.csdn.net/weixin_49769267/article/details/131501614

### 3.1.2 Web 核心考察方向

Web 题目涉及知识面广泛，核心考点主要包括：

- SQL 注入漏洞与利用

- 文件上传漏洞与解析绕过
- PHP 特性与代码执行绕过
- XSS 跨站脚本攻击
- CSRF 跨站请求伪造
- SSRF 服务器端请求伪造
- 反序列化漏洞
- HTTP 协议与请求包构造

## 3.2 Web 常用工具介绍

表 5: Web 题型常用工具清单

| 工具名称 | 工具用途 |
| --- | --- |
| Burp Suite | Web 渗透集成平台，代理、重放、爆破、扫描 |
| Sqlmap | 自动化 SQL 注入检测与利用工具 |
| Hackbar | Firefox 插件，快速构造 HTTP 请求 |
| Dirsearch | Web 目录扫描、隐藏路径爆破 |
| 蚁剑/冰蝎/Weevely | 网站后门管理、文件管理、命令执行 |
| Nmap | 端口扫描、服务探测 |
| Wireshark | HTTP/HTTPS 流量抓包与分析 |

### 3.2.1 Kali Linux 渗透测试系统

Kali Linux 是基于 Debian 的 Linux 发行版，专为渗透测试、数字取证设计，预装大量 Web 安全工具，是 CTF Web 题目的标准实验环境。

- 官网：https://www.kali.org/
- 核心工具：Burp Suite、Sqlmap、Nmap、Wireshark 等

## 3.3 核心工具详解

### 3.3.1 Hackbar 工具

Hackbar 是 Firefox 浏览器插件，用于快速编辑、发送 HTTP 请求，支持编码解码、加密、参数修改，是 Web 入门必备工具。

- 加载 URL、快速修改 GET/POST 参数
- 支持 URL、Base64、16 进制编码解码
- 支持 MD5、SHA1、SHA256 哈希计算
- 一键发送请求，查看响应结果

### 3.3.2 Burp Suite 工具

Burp Suite 是 Web 安全最核心工具，提供完整渗透测试工具链：

- **Proxy**：HTTP/HTTPS 代理，拦截修改请求
- **Repeater**：手动重放 HTTP 请求
- **Intruder**：暴力破解、Fuzz 测试
- **Decoder**：编码解码工具箱

### 3.3.3 SQLmap 工具

SQLmap 是自动化 SQL 注入工具，可自动检测、利用注入漏洞，获取数据库权限、数据。

常用命令：

- 探测注入点：`sqlmap -u "url"`
- 枚举所有数据库：`--dbs`
- 查看表名：`-D 库名 --tables`
- 脱库数据：`--dump`

## 3.4 HTTP 请求协议基础

### 3.4.1 GET 请求

- 用于从服务器获取数据
- 参数直接拼接在 URL 中
- 长度受限、参数可见

### 3.4.2 POST 请求

- 用于向服务器提交数据
- 参数放在请求体中
- 长度无限制、更安全

### 3.4.3 HTTP 常见请求头

- **Host**：目标主机地址
- **User-Agent**：客户端标识
- **Cookie**：用户身份凭证
- **Referer**：请求来源页面
- **X-Forwarded-For**：客户端真实 IP

## 3.5 HTTP 请求示例

### 3.5.1 GET 请求示例

```
GET /index.html HTTP/1.1
Host: www.test.com
User-Agent: Mozilla/5.0
Accept: */*
Connection: close
```

### 3.5.2 POST 请求示例

```
POST /login HTTP/1.1
Host: www.test.com
Content-Type: application/x-www-form-urlencoded
Content-Length: 20

username=admin&password=123
```

## 3.6 Hackbar 使用实验

### 3.6.1 实验目的

- 掌握 GET/POST 请求区别
- 能够使用 Hackbar 构造、修改、发送 HTTP 请求
- 理解 HTTP 请求头作用并能手动修改
- 完成基础 Web 题目测试

### 3.6.2 实验步骤

1. 安装 Firefox 与 Hackbar 插件
2. 加载目标 URL，熟悉工具面板
3. 构造 GET 请求，修改参数并发送
4. 构造 POST 请求，填写请求体数据
5. 修改 Referer、X-Forwarded-For 等请求头
6. 观察服务器响应并记录结果

### 3.6.3 实验要求

- 独立完成 HTTP 请求构造
- 熟练使用编码解码功能
- 提交完整实验记录与测试截图

## 3.7 Web 安全通用解题思路

1. **信息收集**：目录扫描、端口扫描、查看页面源码
2. **抓包分析**：使用 Burp Suite 抓取 HTTP 请求
3. **漏洞判断**：识别 SQL 注入、文件上传、XSS 等漏洞
4. **工具利用**：使用 SQLmap、Hackbar 等完成利用
5. **权限提升**：获取网站权限、读取 flag
6. **提交 flag**

## 3.8 参考文献

1. CTF Wiki Web 安全官方文档：https://ctf-wiki.org/web/

2.《白帽子讲 Web 安全》，吴翰清，电子工业出版社

3.《CTF 特训营：技术详解、解题方法与竞赛技巧》

4. Burp Suite 官方文档：https://portswigger.net/burp/documentation

5. SQLmap 官方使用手册：https://sqlmap.org/

6. HTTP 协议官方标准：https://www.w3.org/Protocols/rfc2616/rfc2616.html